

PRD test2 API 基础设施完整清单

区域: ap-northeast-1 (东京) 账号: 043300555595 架构原则: 无 NAT、私网通信、AWS 服务通过 VPC Endpoint

1. 目标架构



不创建 NAT Gateway; ECS 私有路由表中不配置互联网默认路由。

2. 子网与路由

NLB 公网子网

- zhu-prd-test2-nlb-ap-northeast-1a
- zhu-prd-test2-nlb-ap-northeast-1c

要求: 关联 0.0.0.0/0 → Internet Gateway 的公网路由表。

ALB / ECS 私有子网

- 两个 AZ 各一个私有子网
- 不分配 Public IP
- 不配置 NAT/Internet 默认路由
- 关联 S3 Gateway Endpoint

3. Load Balancer 与 Target Group

用途	名称
NLB → ALB 443	zhu-prd-test2-nlb-alb-443
NLB → ALB 10443	zhu-prd-test2-nlb-alb-10443
ALB → ECS TG 01	zhu-prd-test2-alb-ecs-tg-01
ALB → ECS TG 02	zhu-prd-test2-alb-ecs-tg-02

4. Security Group 规则

NLB SG

方向	协议/端口	来源或目标
入站	TCP 443	允许访问系统的客户端 CIDR
入站	TCP 10443	公司/运维出口 CIDR
出站	TCP 443、10443	ALB SG

ALB SG

方向	协议/端口	来源或目标
入站	TCP 443、10443	NLB SG
出站	TCP 80	ECS SG

ECS SG

方向	协议/端口	来源或目标
入站	TCP 80	ALB SG
出站	TCP 443	VPC Endpoint SG
出站	TCP 443	S3 Prefix List
出站	TCP 5432 或 3306	Aurora SG (按引擎选择)
出站	TCP 6379	Redis SG
出站	实际应用端口	同 VPC 其他 API SG

删除 ECS 当前的 `0.0.0.0/0 + all protocols` 全开放出站，改为按目标 SG 精确授权。

VPC Endpoint SG

方向	协议/端口	来源
入站	TCP 443	ECS SG

Aurora、Redis、其他 API SG

- Aurora PostgreSQL: 入站 TCP 5432, 来源 ECS SG。

- Aurora MySQL: 入站 TCP 3306, 来源 ECS SG。
- Redis: 入站 TCP 6379, 来源 ECS SG。
- 其他 API: 入站实际应用端口, 来源 test2 ECS SG。

5. VPC Endpoint

必须的 Interface Endpoint

- `com.amazonaws.ap-northeast-1.ecr.api`
- `com.amazonaws.ap-northeast-1.ecr.dkr`
- `com.amazonaws.ap-northeast-1.logs`

放置在两个 ECS 私有子网, 关联 Endpoint SG, 并设置 `private_dns_enabled = true`。

必须的 Gateway Endpoint

- `com.amazonaws.ap-northeast-1.s3`, 关联 ECS 私有路由表。

按需增加

`secretsmanager`、`ssm`、`kms`、`ssmmessages`、`sts`、`sqs`、`sns`、`execute-api`、`xray`、`monitoring`。

6. ECR 与 ECS

ECR Repository

创建 `zhu-prd-test2-api`，启用镜像扫描、Tag 不可变和生命周期策略。

当前 `httpd:latest` 来自 Docker Hub；无 NAT 环境无法拉取。必须改用 ECR，并使用 Git commit SHA 等固定版本 Tag。

Task Definition

- 使用 ECR 镜像 URI。
- 容器端口 80。
- CloudWatch Logs。
- 删除挂载到根目录 `/` 的空 Volume，或改到真实数据目录。
- 通过 Secrets Manager/SSM 注入数据库、Redis 和其他 API 配置。

7. IAM

- **Execution Role**: ECR 拉取、CloudWatch Logs、读取 Task Definition 引用的 Secret。
- **Task Role**: 仅授予应用需要的 Secrets Manager、SSM、S3、SQS、SNS、KMS 等权限。
- **CodeBuild Role**: ECR Push、Logs、Artifact S3、必要 KMS 权限。
- **CodePipeline Role**: CodeCommit、CodeBuild、CodeDeploy、S3、PassRole。
- **CodeDeploy Role**: ECS、Target Group、Listener、Task Set 操作权限。

8. 配置与密钥

Secrets Manager 保存用户名、密码、Redis Token；Parameter Store 保存 Endpoint、端口、数据库名、其他 API Base URL。禁止将密码写入 Terraform 源码。

9. HTTPS 与 DNS

1. 准备真实域名与 Route 53 DNS。
2. 申请状态为 `ISSUED` 的 ACM 证书。
3. 设置 `alb_certificate_arn`，将临时 HTTP 切换为 HTTPS。
4. 将包含下划线的测试 Hostname 改为合法名称，例如 `api-test2.prd.example.com`。

10. CI/CD

Source → Build → Manual Approval → CodeDeploy Blue/Green

需要准备 `Dockerfile`、`buildspec.yaml`、`appspec.yaml`、`taskdef.json`，并增加 CodeCommit → EventBridge → CodePipeline 自动触发。

11. 监控

- ECS Running Task、CPU、Memory
- ALB Healthy Host、5xx、响应时间
- Pipeline、Build、Deploy 失败
- Aurora CPU、连接数、存储
- Redis CPU、内存、连接数、Evictions
- SNS/Chatbot 通知

12. 实施顺序

1. 创建 ECR 并推送业务镜像。
2. 创建 Endpoint SG。
3. 创建 ECR API、ECR DKR、Logs、S3 Endpoint。
4. 收紧 ECS 出站规则。
5. 增加 Aurora、Redis、其他 API 安全组规则。
6. 修正 Task Definition。
7. 补全 CI/CD 文件并验证 Pipeline。
8. 确认 ECS Desired 1 / Running 1、Target healthy。
9. 配置正式域名、ACM 和 HTTPS。
10. 增加监控告警。

完成标准： Terraform 无差异；ECS Running=1；Target healthy；Pipeline 含人工审批并可完成 Blue/Green；没有 NAT；AWS 服务走 Endpoint；数据库、Redis和其他 API 走同 VPC 私网。